

Cybersecurity Daily Newsletter

Vol. 006 | 2026-10-08 09:00 WIB

Top 5 Highlights

- Ransomware recovery CEO charged over secret ransom payments
- Cisco quantum network controller lets apps order entanglement on demand
- Evolution of Web3 in Cloud Supply Chain Attacks
- Configuring your AI vulnerability harness, Part 2: The steering file
- Building your AI vulnerability harness, Part 1

Threat Intelligence (10)

01. Eight Malicious npm Packages Downloaded 40,767 Times Deliver Overlord RAT and Stealer

Cybersecurity researchers have disclosed details of a long-running npm supply chain malware campaign that pushes information stealers and remote access trojans (RAT) to compromised hosts. The campaign has been codenamed Malfex by CloudSEK and Checkmarx. The activity is assessed to be the work of a lone threat actor who appears to have published 12 packages...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://thehackernews.com/2026/10/eight-malicious-npm-packages-downloaded.html>

02. Poetry is the new AI security threat as PoeLLM malware infects 3K+ servers

Quoth the LLM, 'More and more'

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.theregister.com/security/2026/10/07/poetry-is-the-new-ai-security-threat-as-poellm-malware-infects-3k-servers/5301672>

03. PoeLLM Malware Infects 3,400+ Servers to Expand Crypto Mining Botnet

Cybersecurity researchers are calling attention to a new malware family that has been observed targeting exposed artificial intelligence (AI) and large language model (LLM) infrastructure with an aim to deploy cryptocurrency miners and further expand the scale of the botnet. The financially motivated campaign, dubbed Canto Incognito, has been found to insta...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/10/poellm-malware-infects-3400-servers-to.html>

04. PoeLLM malware infects exposed AI servers in cryptomining attacks

A cryptomining campaign targeting exposed AI services is using PoeLLM malware to turn compromised servers into scanners and exploit launchpads. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/poellm-malware-infected-exposed-ai-servers-in-cryptomining-attacks/>

05. Vijil DART tests AI agents for security flaws and policy violations

Vijil has released Diamond Adaptive Red Teaming for Agents (DART), an automated testing system that finds security vulnerabilities and policy violations in enterprise AI agents. DART employs multiple adversarial agents of its own to probe the target's defenses with multi-turn attacks that learn and adapt tactics across turns, episodes, and engagements. Usin...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources:

<https://www.helpnetsecurity.com/2026/10/07/vijil-diamond-adaptive-red-teaming-for-agents-dart/>

06. Hoxhunt expands Respond to automate phishing investigations and email removal

Hoxhunt has announced expanded capabilities for Hoxhunt Respond, its email incident response automation platform for security operations teams. Respond can reduce phishing tickets requiring analyst attention by up to 99% and remediate confirmed malicious campaigns in under one minute. Effective phishing training creates a valuable result: employees recogniz...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.helpnetsecurity.com/2026/10/07/hoxhunt-respond/>

07. Attackers Hide AI Prompt Injections Inside Phishing Emails

Barracuda finds phishing emails designed to manipulate both human users and AI assistants

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.infosecurity-magazine.com/news/attackers-hide-ai-prompt/>

08. [+24h Old] 100+ Compromised Websites Use Fake Cloudflare Checks to Deliver LunexStealer

The Computer Emergency Response Team of Ukraine (CERT-UA) has identified more than 100 compromised websites that have been injected with malicious JavaScript to serve an

information-stealing malware called LunexStealer (aka Psychedelic Stealer). The activity, which was observed by the agency in September 2026, has been attributed to a threat cluster dubbed...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/10/100-compromised-websites-use-fake.html>

09. [+24h Old] ISC Stormcast For Wednesday, October 7th, 2026 <https://isc.sans.edu/podcastdetail/10126>, (Wed, Oct 7th)

ISC Stormcast For Wednesday, October 7th, 2026
<https://isc.sans.edu/podcastdetail/10126>, (Wed, Oct 7th)

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://isc.sans.edu/diary/rss/33404>

10. [+24h Old] Fake ChatGPT, Gemini, and Claude Ad Portals Capture Credentials and MFA Codes

Cybersecurity researchers have disclosed details of a "human-operated phishing platform" that impersonates advertising products for artificial intelligence (AI) chatbots like Google Gemini, Anthropic Claude, OpenAI ChatGPT, Perplexity, Meta Muse, and Manus. The products, which claim to offer campaign optimization, spend audits, and business-account connecti...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://thehackernews.com/2026/10/fake-chatgpt-gemini-and-claude-ad.html>

Latest Vulnerabilities (10)

01. Cisco quantum network controller lets apps order entanglement on demand

Cisco has built a Quantum Network Controller, a research prototype that lets an application ask a quantum network for entanglement and leaves the network to work out the delivery. Entanglement, a linked quantum state shared between distant points, is the resource these networks distribute, and operators today set up the hardware that produces it device by d...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.helpnetsecurity.com/2026/10/08/cisco-quantum-network-controller-research-prototype/>

02. Evolution of Web3 in Cloud Supply Chain Attacks

Unit 42 details how threat actors leverage Web3 infrastructure and open-source supply chain attacks to breach enterprise cloud environments. The post Evolution of Web3 in Cloud Supply Chain Attacks appeared first on Unit 42 .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://unit42.paloaltonetworks.com/web3-cloud-supply-chain-attacks/>

03. Configuring your AI vulnerability harness, Part 2: The steering file

This post shows you how to configure an AI model to perform structured, evidence-based vulnerability triage with the consistency of a seasoned security analyst. You'll learn the design decisions behind five configuration sections that enforce structural verification, evidence-based scoring, and infrastructure-aware prioritization across every analysis session...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://aws.amazon.com/blogs/security/configuring-your-ai-vulnerability-harness-part-2-the-steering-file/>

04. Building your AI vulnerability harness, Part 1

Vulnerability scanners produce findings faster than manual triage can process them. Your developers ship more code with more dependencies, and the volume of candidate findings grows with it. Many findings a scanner produces are unlikely to be exploited. The ones that matter need to reach an engineer fast, with enough evidence that they can act [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://aws.amazon.com/blogs/security/building-your-ai-vulnerability-harness-part-1/>

05. AWS launches open-source AI agent sandbox to prevent YOLO mode disasters

Strands Box is the latest open source AI control tool from the cloud giant; like its predecessors, it promises tighter reins on autonomous agents

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.theregister.com/ai-and-ml/2026/10/07/aws-launches-open-source-ai-agent-sandbox-to-prevent-yolo-mode-disasters/5301687>

06. SonicWall Patches CVSS 10.0 Pre-Authentication SSRF Flaw in SMA1000 Appliances

SonicWall has released hotfixes for four flaws in its SMA1000 appliances, the gateways that give remote workers access to a company's network and applications. The most serious could allow an attacker without a login to send requests through the appliance and reach internal functions. SonicWall rates it 10.0 on the CVSS scale and says it has no evidence tha...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/10/sonicwall-patches-cvss-100-pre.html>

07. 3 lessons from frontier AI vulnerability research

Read how How Microsoft Security's FORGE Lab is scaling vulnerability research from Windows to the Linux kernel. The post 3 lessons from frontier AI vulnerability research appeared first on Microsoft Security Blog .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.microsoft.com/en-us/security/blog/2026/10/07/3-lessons-from-frontier-ai-vulnerability-research/>

08. Unpatched Critical LMCACHE Flaw Lets Unauthenticated Attackers Run Code Remotely

A critical vulnerability in LMCACHE, open-source software that speeds up large language model (LLM) servers such as vLLM, lets an attacker run code on the cache server without logging in, and no fixed version is available. The flaw is in LMCACHE's multiprocess mode, where the cache runs as a standalone server that LLM workers reach over the ZeroMQ messaging...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/10/unpatched-critical-lmcache-flaw-lets.html>

09. Atlassian warns of critical arbitrary file access vulnerability in self-hosted products

Atlassian warns of critical arbitrary file access vulnerability in self-hosted products

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/atlassian-warns-of-critical-arbitrary-file-access-vulnerability-in-self-hosted-products>

10. Scans for Atlassian vulnerability (CVE-2026-21589), (Wed, Oct 7th)

On October 5th, Atlassian published patches for multiple products to fix an "Arbitrary File Access" vulnerability (CVE-2026-21589). An attacker can read arbitrary files in the web application's directory, potentially exposing sensitive information such as configuration files.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://isc.sans.edu/diary/rss/33406>

Data Breach & Cybercrime (10)

01. Ransomware recovery CEO charged over secret ransom payments

The owner of ransomware remediation company MonsterCloud has been charged with allegedly defrauding ransomware victims by secretly paying their attackers for decryptors while claiming to use proprietary technology to recover encrypted data. [...]

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.bleepingcomputer.com/news/security/ransomware-recovery-ceo-charged-over-secret-ransom-payments/>

02. Hackers hijack Google domains after breaching ccTLD registries

Hackers obtained unauthorized HTTPS certificates for several Google domains and hijacked domains in the country-code top-level domains (ccTLDs) for Ghana, American Samoa, and Sierra Leone after compromising third-party operators and modifying authoritative DNS records. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/hackers-hijack-google-domains-after-breaching-cctld-registries/>

03. FortiBleed campaign still attacking Fortinet devices, US agencies warn

FBI warns FortiBleed attackers remain active, turning stolen credentials into persistent access.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.scworld.com/news/fortibleed-campaign-still-attacking-fortinet-devices-us-agencies-warn>

04. Attackers Hijack .gh, .sl, and .as Registries to Obtain Certificates for Google Domains

Attackers compromised three country-code top-level domains (ccTLDs) and obtained unauthorized HTTPS certificates for several Google domains, Google said on October 6. Google's own systems were not breached, but any domain ending in .gh (Ghana), .sl (Sierra Leone) or...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://thehackernews.com/2026/10/attackers-hijack-gh-sl-and-as.html>

05. FortiBleed campaign targets Fortinet devices, leading to ransomware

FortiBleed campaign targets Fortinet devices, leading to ransomware

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources:

<https://www.scworld.com/brief/fortibleed-campaign-targets-fortinet-devices-leading-to-ransomware>

06. Bromcom notifies customers of personal data breach affecting SSO technology

UK education software provider Bromcom alerted its customers to a personal data breach impacting its single sign-on (SSO) technology, potentially exposing email addresses and other limited information.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.scworld.com/brief/bromcom-notifies-customers-of-personal-data-breach-affecting-so-technology-5650>

07. Georgia Power, Alabama Power Data Breach Hits 400,000 Accounts

Southern Company is notifying customers that their utility account information was accessed by hackers. The post Georgia Power, Alabama Power Data Breach Hits 400,000 Accounts appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.securityweek.com/georgia-power-alabama-power-data-breach-hits-400000-accounts/>

08. Ransomware has a new target. Is your backup ready?

Ransomware groups are increasingly targeting backup infrastructure to eliminate recovery options and increase pressure on victims to pay. Kaseya explains why organizations need isolated, immutable, and regularly tested backups that attackers cannot easily reach. [...]

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources:

<https://www.bleepingcomputer.com/news/security/ransomware-has-a-new-target-is-your-backup-ready/>

09. ShinyHunters Extorted Boeing Spin-off Prior to Arrests

A teenager from Amman, Jordan suspected of leading the prolific data theft and extortion group ShinyHunters has been detained and is reportedly cooperating with the FBI to identify other members of the hacking gang. KrebsOnSecurity has learned that the suspect, who uses the hacker handle "Rey," was detained as ShinyHunters was in the process of extorting a...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://krebsonsecurity.com/2026/10/shinyhunters-extorted-boeing-spin-off-prior-to-arrests/>

10. Qilin Ransomware Suspect Arrested in Japan, Extradited to Germany

The individual was detained in May and has been extradited to Germany to face hacking charges. The post Qilin Ransomware Suspect Arrested in Japan, Extradited to Germany appeared first on SecurityWeek .

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources:

<https://www.securityweek.com/qilin-ransomware-suspect-arrested-in-japan-extradited-to-germany/>